



Matriz de Riesgos

Gobierno de TI | IT Governance

Profesora: Palacios Solano Rocío

Grupo 7CV4

Elaboró: Rojo Ibarra Jesús

Periodo Escolar 26/2

Fecha de entrega: 17 de junio de 2026

ACTIVO			VALORACIÓN					
ID_PROCESO	ID_ACTIVO	ACTIVO DE INFORMACIÓN	C	I	D	TOTAL	VALOR 1	VALOR 2
SSO_PROC_1	SSO_HW_01	Estaciones de trabajo del equipo ofensivo	5	5	5	15	Alto	3
	SSO_DOC_01	Documentos legales	4	4	3	11	Alto	3
SSO_PROC_2	SSO_HW_02	VPS / Infraestructura aislada	5	5	5	15	Alto	3
	SSO_HW_01	Herramientas de pentesting	5	4	4	13	Alto	3
	SSO_DB_01	Bases de datos de vulnerabilidades (CVE)	4	4	3	11	Alto	3
	SSO_SW_02	Plataforma de phishing	4	4	3	11	Alto	3
SSO_PROC_3	SSO_SW_03	Sistema de generación de reportes	4	4	4	12	Alto	3
	SSO_DB_02	Almacenamiento cifrado de evidencias	5	5	5	15	Alto	3
	SSO_DOC_02	Informes finales	5	5	5	15	Alto	3

VULNERABILIDADES	AMENAZAS	EVENTO DE AMENAZA	CONTROLES
Acceso físico no controlado a estaciones de trabajo	Robo de equipos, acceso no autorizado	Pérdida de información confidencial del cliente	Control de accesos físicos, cifrado de discos, políticas de escritorio limpio
Falta de cifrado en comunicaciones	Interceptación de tráfico (MITM)	Exposición de hallazgos o credenciales durante pruebas	VPN, TLS 1.3, comunicaciones cifradas
Configuración insegura de herramientas de pentesting	Uso malicioso o error de configuración	Ejecución fuera de alcance, daño a sistemas del cliente	Segmentación de red, revisiones previas, RoE estricto
Falta de respaldo de evidencias	Fallo de hardware, error humano	Pérdida de hallazgos críticos, retraso en entrega	Respaldos diarios cifrados, almacenamiento redundante
Accesos excesivos a bases de datos de vulnerabilidades	Fuga de información, malware	Exposición de exploits y técnicas sensibles	Control de accesos basado en roles (RBAC), monitoreo de accesos
Falta de segmentación de red	Propagación de malware, acceso no autorizado	Compromiso de infraestructura aislada	VLANs dedicadas, firewalls, VPS aislados
Dependencia de conectividad a internet	Fallo de ISP, ataque DDoS	Interrupción de pruebas en curso	Conexiones redundantes, modo offline para herramientas críticas

Configuración deficiente de reportes	Error humano, manipulación	Entrega de informes incompletos o alterados	Revisión por pares, firmas digitales, cifrado de reportes
Falta de destrucción segura de datos	Recuperación no autorizada post-servicio	Exposición de datos del cliente	Borrado seguro certificado, constancia de destrucción

Análisis de Vulnerabilidades

Vulnerabilidad	Severidad	Exposición	Valor
Acceso físico no controlado a estaciones de trabajo	3	3	5
Falta de cifrado en comunicaciones	3	2	4
Configuración insegura de herramientas de pentesting	3	2	4
Falta de respaldo de evidencias	2	3	4
Accesos excesivos a bases de datos de vulnerabilidades	3	3	5
Falta de segmentación de Red	3	2	4
Dependencia de conectividad a Internet	2	2	3
Configuración deficiente de reportes	2	2	3
Falta de destrucción segura de datos	4	3	5

Análisis de Amenazas

Amenaza	Evento de Amenaza	Capacidad	Motivación	Valor
Error humano	Configuración incorrecta, pérdida de evidencias	2	2	3

Ciberataque	Robo o alteración de hallazgos	3	3	5
Fallo de red	Indisponibilidad durante pruebas	3	2	3
Robo de equipos	Pérdida de información confidencial	2	2	3
Malware	Compromiso de infraestructura ofensiva	3	3	5
Acceso no autorizado interno	Exposición de metodologías y herramientas	2	3	4

Riesgo de control = Amenaza * Vulnerabilidad * Probabilidad * Impacto

Amenaza	Vulnerabilidad	Probabilidad	Impacto	Riesgo Total
3	5	3	10	450
5	4	2	15	600
3	4	3	15	540
3	3	2	12	216
5	5	3	13	975
4	5	4	11	880

ACTIVO			VALORACIÓN						
ID_PROCESO	ID_ACTIVO	ACTIVO DE INFORMACIÓN	Área geográfica	Periodo de afectación	IMPACTO	Cantidad de Infraestructuras Críticas Afectadas	Campos Afectados	INDEPENDENCIA	CRITICIDAD
SSO_PROC_1	SSO_HW_01	Estaciones de trabajo del equipo ofensivo	3	3	3	3	2	5	V
	SSO_DOC_01	Documentos legales	2	2	2	2	2	4	IV
SSO_PROC_2	SSO_HW_02	VPS / Infraestructura aislada	3	3	3	3	3	5	V
	SSO_HW_01	Herramientas de pentesting	3	2	3	2	2	4	IV
	SSO_DB_01	Bases de datos de vulnerabilidades (CVE)	2	2	2	2	2	3	III
	SSO_SW_02	Plataforma de phishing	2	2	2	2	2	3	III
SSO_PROC_3	SSO_SW_03	Sistema de generación de reportes	2	2	2	2	2	3	III
	SSO_DB_02	Almacenamiento cifrado de evidencias	3	3	3	3	3	5	V
	SSO_DOC_02	Informes finales	3	3	3	3	3	5	V

IDENTIFICACIÓN DE INFRAESTRUCTURAS CRÍTICAS		
INFRAESTRUCTURAS CRÍTICAS DETECTADAS	GRADO DE CRITICIDAD	CONTROLES A IMPLEMENTAR
Estaciones de trabajo del equipo ofensivo	V	Control de accesos físicos, cifrado de discos, políticas de escritorio limpio, autenticación MFA, monitoreo de actividad.
Documentos legales	IV	Almacenamiento cifrado, control de versiones, accesos restringidos por rol, respaldos en ubicación segura, retención por 3 años posterior al cierre del servicio.
VPS / Infraestructura aislada	V	Segmentación de red dedicada, firewalls, actualización semanal de parches, conexiones VPN obligatorias, monitoreo 24/7 de tráfico.
Herramientas de pentesting	IV	Actualización constante de firmas CVE, licencias vigentes, ejecución en entornos aislados, validación previa a cada prueba, logs de actividad.
Bases de datos de vulnerabilidades	III	Respaldos diarios cifrados, control de accesos basado en roles (RBAC), monitoreo de accesos no autorizados, sincronización con fuentes oficiales NVD.

Plataforma de phishing	III	Acceso restringido al equipo autorizado, plantillas validadas previamente, registros de campañas, eliminación segura de datos de destinatarios post-campaña.
Sistema de generación de reportes	III	Acceso restringido al equipo autorizado, plantillas validadas previamente, registros de campañas, eliminación segura de datos de destinatarios post-campaña.
Almacenamiento cifrado de evidencias	V	Cifrado AES-256 en reposo y tránsito, respaldos incrementales diarios, acceso solo por personal autorizado, destrucción segura certificada post-cierre.
Informes finales	V	Entrega cifrada por canal seguro, firmado digitalmente, acceso restringido al cliente y líder de proyecto, destrucción de copias locales tras entrega.